

Skills Check

Which three internet job boards allow filtering job postings by seniority or experience level? (Choose three.)

☒ glassdoor.com

☒ indeed.com

☒ linkedin.com jobs

☐ monster.com

1.2.4 Practice - Types of Penetration Tests

Protego has been contracted to do a network infrastructure test as part of a broader penetration testing engagement. What will you be targeting in this test? (Choose three.)

☐ virtual machines (VM) that are running in the cloud

☐ the digital storefront

☒ AAA servers

☒ IPS devices

☒ switches

Skills Check

Under what tactic in the MITRE ATT&CK matrix would you find the information gathering stage of the Operation Dream Job procedure?

☐ Collection

☐ Credential Access

☐ Initial Access

☐ Privilege Escalation

☒ Reconnaissance

☐ I don't know

1.3.4 Practice - Requirements and Guidelines for Penetration Testing Labs

You need to setup a penetration testing practice lab because some of the tools that are preferred at Protego are new to you. What best practices will you follow as you setup your lab? (Choose three.)

- ☒ Ensure closed access to the network and internet.
- ☒ Create a virtualized computing environment.
- ☒ Provide sufficient hardware resources to ensure valid results.
- ☐ Utilize the same tool for consistent results.
- ☐ Test using one common operating system.
- ☐ Use hardened targets for more challenging tests.

Skills Check

You have just downloaded and installed VirtualBox or UTM. You start the application, but you do not see the Kali VM running. What step did you forget?

- ☐ You need to update the install files to the latest version.
- ☒ You must download and import or run the Kali VM file in VirtualBox or UTM.
- ☐ There may be an issue with the installation. Remove and reinstall VirtualBox or UTM.
- ☐ You must use VirtualBox or UTM to browse to the virtual machine on the kali.org website.

Skills Check

You have just started Kali and open a terminal from the panel. What will the response be when you enter the **pwd** command at the prompt?

- ☐ /home
- ☐ /kali/~
- ☒ /home/kali
- ☐ /root/kali

Question 1

Which statement best describes the term ethical hacker?

a person who uses different tools than nonethical hackers to find vulnerabilities and exploit targets

a person that is financially motivated to find vulnerabilities and exploit targets

a person that is looking to make a point or to promote what they believe



a person who mimics an attacker to evaluate the security posture of a network

Question 2

Which threat actor term describes a well-funded and motivated group that will use the latest attack techniques for financial gain?

hactivist

state-sponsored attacker



organized crime

insider threat

Question 3

Which type of threat actor uses cybercrime to steal sensitive data and reveal it publicly to embarrass a target?

organized crime



hactivist

insider threat

state-sponsored attacker

Question 4

What is a state-sponsored attack?

An attack perpetrated by a well-funded and motivated group that will typically use the latest attack techniques for financial gain.



An attack perpetrated by governments worldwide to disrupt or steal information from other nations.

An attack perpetrated by disgruntled employees inside an organization.

An attack is perpetrated to steal sensitive data and then reveal it to the public to embarrass or financially affect a target.

Question 5

What is an insider threat attack?

An attack perpetrated by a well-funded and motivated group that will typically use the latest attack techniques for financial gain.

An attack perpetrated by governments worldwide to disrupt or steal information from other nations.



An attack perpetrated by disgruntled employees inside an organization.

An attack is perpetrated to steal sensitive data and then reveal it to the public to embarrass or financially affect a target.

Question 6

What kind of security weakness is evaluated by application-based penetration tests?

firewall security



logic flaws

wireless deployment

data integrity between a client and a cloud provider

Question 7

What two resources are evaluated by a network infrastructure penetration test? (Choose two.)

- ☒ AAA servers
- ☐ CSPs
- ☐ web servers
- ☒ IPSs
- ☐ back-end databases

Question 8

When conducting an application-based penetration test on a web application, the assessment should also include testing access to which resources?

- ☐ AAA servers
- ☐ cloud services
- ☐ switches, routers, and firewalls
- ☒ back-end databases

Question 9

What is the purpose of bug bounty programs used by companies?

- ☒ reward security professionals for finding vulnerabilities in the systems of the company
- ☐ reward security professionals for discovering malicious activities by attackers in the systems of the company
- ☐ reward security professionals for fixing vulnerabilities in the systems of the company
- ☐ reward security professionals for breaking into a corporate facility to expose weaknesses in the physical perimeter

Question 10

What characterizes a partially known environment penetration test?

- The tester must test the electrical grid supporting the infrastructure of the target.
- The tester is provided with a list of domain names and IP addresses in the scope of a particular target.
- ☒ The test is a hybrid approach between unknown and known environment tests.
- The tester should not have prior knowledge of the organization and infrastructure of the target.

Question 11

What characterizes a known environment penetration test?

- The test is somewhat of a hybrid approach between unknown and known environment tests.
- ☒ The tester could be provided with network diagrams, IP addresses, configurations, and user credentials.
- The tester should not have prior knowledge of the organization and infrastructure of the target.
- The tester may be provided only the domain names and IP addresses in the scope of a particular target.

Question 12

Which type of penetration test would only provide the tester with limited information such as the domain names and IP addresses in the scope?

- known-environment test
- partially known environment test
- ☒ unknown-environment test
- OWASP Web Security Testing Guide

Question 13

Match the penetration testing methodology to the description.

Categories:

OSSTMM

NIST SP 800-115

MITRE ATT&CK

OWASP WSTG

PTES

Options:

collection of different matrices of tactics and techniques that adversaries use while preparing for an attack

covers the high-level phases of web application security testing

provides organizations with guidelines on planning and conducting information security testing

lays out repeatable and consistent security testing

provides information about types of attacks and methods

A

B

C

D

E

C

D

B

A

E

Question 14

Which three options are phases in the Penetration Testing Execution Standard (PTES)? (Choose three.)

Threat modeling

Penetration

Reporting

Enumerating further

Network mapping

Exploitation

Question 15

Which two options are phases in the Information Systems Security Assessment Framework (ISSAF)? (Choose two.)

- Pre-engagement interactions
- ☒ Maintaining access
- Reporting
- Post-exploitation
- ☒ Vulnerability identification

Question 16

Which two options are phases in the Open Source Security Testing Methodology Manual (OSSTMM)? (Choose two.)

- Vulnerability Analysis
- Maintaining Access
- ☒ Work Flow
- Network Mapping
- ☒ Trust Analysis

Question 17

Which penetration testing methodology is a comprehensive guide focused on web application testing?

- MITRE ATT&CK
- ☒ OWASP WSTG
- NIST SP 800-115
- OSSTMM

Question 18

Which option is a Linux distribution that includes penetration testing tools and resources?

- OWASP
- PTES
- SET
- ☒ BlackArch

Question 19

Which option is a Linux distribution URL that provides a convenient learning environment about pen testing tools and methodologies?

- vmware.com
- attack.mitre.org
- ☒ parrotsec.org
- virtualbox.org

Question 20

What does the "Health Monitoring" requirement mean when setting up a penetration test lab environment?

- The tester needs to be sure that a lack of resources is not the cause of false results.
- ☒ The tester needs to be able to determine the causes when something crashes.
- The tester needs to ensure controlled access to and from the lab environment and restricted access to the internet.
- The tester validates a finding running the same test with a different tool to see if the results are the same.

Question 21

Which tool would be useful when performing a network infrastructure penetration test?

- vulnerability scanning tool
- ☒ bypassing firewalls and IPSs tool
- interception proxies tool
- mobile application testing tool

Question 22

Which tool should be used to perform an application-based penetration test?

- sniffing traffic tool
- bypassing firewalls and IPSs tool
- ☒ interception proxies tool
- cracking wireless encryption tool

Question 23

Which tools should be used to perform a wireless infrastructure penetration test?

- web vulnerability detection tools
- traffic manipulation tools
- proxy interception tools
- ☒ de-authorizing network devices tools

Question 24

Which tools should be used for testing the server and client platforms in an environment?

- cracking wireless encryption tools
- ☒ vulnerability scanning tools
- interception proxies tools
- de-authorizing network devices tools

Question 25

Sometimes a tester cannot virtualize a system to do the proper penetration testing. What action should be taken if a system cannot be tested in a virtualized environment?

- ☒ a full backup of the system
- rebuild the system after any test is performed
- adopt penetration test tools that will certainly not damage the system
- a complete report with recommended repairs